Securing the Enterprise with the ESP

trimarcsecurity.com/hub-post/securing-the-enterprise-with-the-esp

Mike Fahey May 24, 2022

Updated: Dec 13, 2024

Introduction

We are excited to announce our new Enterprise Security Posture (ESP) assessment for moderately sized to large organizations.

The Trimarc Enterprise Security Posture (Trimarc ESP) assessment is an enterprise-grade security assessment that merges offensive and defensive disciplines to identify strategic security risks impacting our customers. Strategic risks allow threats to extort, manipulate, or compromise high value assets and data critical to the business. The Trimarc ESP Identifies and links technical security issues across technologies, business operations, and security controls to demonstrate strategic risks such as specific accounts that have highly privileged access despite being regular user accounts (for example).

The Trimarc ESP achieves this by looking at key technologies as well as IT and business operations. Trimarc works with our customers to identify assets critical to business operations then discovers and analyzes systemic risks. This approach allows Trimarc to develop impactful remediation plans and tools that work for your enterprise which enables more rapid resolution of identified issues.

In addition to leveraging the immense knowledge from the Trimarc team and our Active Directory (AD), Azure AD, and VMware assessments, we analyze:

- User and administrator behavior
- Security monitoring capabilities
- Windows workstation and server configurations

We "connect the dots" and quantify the risks in your enterprise. The result is a report that provides a detailed list of risks in the environment attached to root causes behind the issue and a roadmap with recommendations on how the risks can be mitigated. This allows customers to focus on the most valuable areas of improvement at a deeper level than traditional security assessments.

Enterprise Risk in a Nutshell

Adversaries are taking advantage of systemic, strategic risks of large enterprises to compromise Active Directory, VMware, cloud services, and other assets critical to the

business. In the news, we have all seen reports on adversaries:

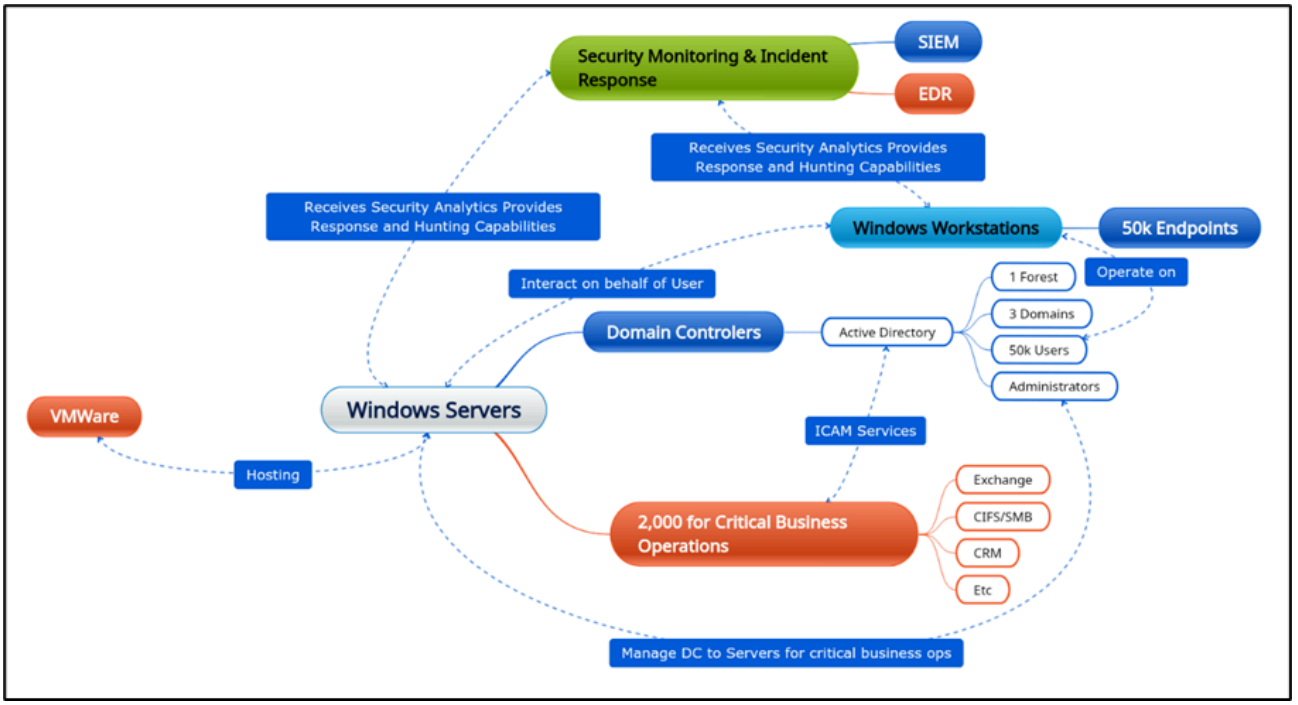
- Using malware to ransom victims at the threat of loss of business; and
- Advanced persistent threats compromising government networks or stealing trade secrets.

What creates these risks? As the great Dr. Ian Malcolm once said, “Life will find a way.” :)

Issues are typically presented by operations of regular users, administrators, business requirements, and decision makers due to operational requirements and poor security practices. As these security issues are introduced, they tend to cascade, grow, or drift over time building on other security issues across the enterprise to create systemic, strategic risk. Enterprises are made up of many different technologies, sub-organizations, and teams which lead the design, management, and implementation of business, IT, and security operations. These entities are constantly changing, interact, and typically depend on one another.

“Technical Debt” is the process, technology, systems, and/or applications that the organization has grown to depend on which involves some level of security risk. Often these are legacy systems which reduce security capability since newer, more secure protocols are not possible with the system in place. Technical debt is further complicated by the typically enterprise configuration:

- Key business operations depend on IT operations to manage their systems
- IT operations depend on security operations to:
    - Detect and response to threats via security monitoring teams
    - Identify vulnerabilities and exposure in IT technology via vulnerability management, penetration testing, and other security teams
- Security monitoring teams depend on IT operations to provide telemetry to be able to detect adversarial activity



Often issues in one operational area directly impact the security of another. One straight forward example of this is how a compromised VMware administrator account could impact the security of all other operations in the enterprise. As an enterprise's infrastructure expands, many subtle issues arise across assets and operations creating a spider web of risk which can heavily impact security. Therefore, we developed the Trimarc ESP that aims to identify, prioritize, and build a roadmap to solve these multi-disciplinary systemic risks.

A Big Impact on Enterprise Security

The Trimarc ESP helped our customers with large enterprises to identify, manage, and resolve high impact and complex cyber security risks. Our approach and reporting have:

- Identified risks strategic to the security of the business missed by traditional security assessments.
- Empowered leaders and teams, from executives to analysts, to effectively resolve complex risks with minimal cost.

We broadly achieve this by:

- **Identifying Customer High Value Assets:** We work with our customers to define critical and key business assets across their enterprise. This typically includes enterprise technologies important to the business such as Active Directory and services critical to the business of our customer like human resources or account receivable system/applications.

- **Understanding Our Clients Environments:** We collaborate with our customers to understand their environment which improves the report coverage and quality. We gain telemetry from thousands even tens of thousands of entities throughout the enterprise with Trimarc's software and processes:

    The security monitoring stack (SIEM and EDR), Windows workstations and servers, Active Directory, and more.

- **Analyzing the Entity Data:** to identify security issues across different technologies. We look for security issues like:

    Risky user behavior, design and configurations of Microsoft Windows, excessive privileges and rights across Windows, applications, and Active Directory, and gaps in security monitoring.

- **Connecting the Dots:** by identifying, linking, and providing proof of security issues across assets and operations throughout the enterprise.

Trimarc's Methodology

Trimarc performs the ESP by leveraging our existing methodology that powers the Trimarc Active Directory Security Assessment (ADSA) which provides in-depth security posture analysis of the AD environment. This AD data is effectively the first step in analyzing the security posture of the enterprise. The next phase is leveraging the Trimarc telemetry capture system (developed specifically for the Trimarc ESP) which enables us to identify risks throughout the environment, including workstations and servers. With this data set, we then correlate AD accounts with rights, behavior, password risk, and more.

The primary benefit of this approach is that we don't start with specific access paths. Instead, we look at the enterprise as a whole, from the top level down to specific systems. From this we identify how connection points provide an attacker the ability to move laterally, escalate permissions, deploy ransomware, and persist.

Some of the Trimarc ESP assessment key components:

- Identification of users, including administrator and service accounts, with weak/vulnerable passwords that could be compromised via password spraying and/or Kerberoasting.

- Analysis of the event monitoring and central event collection system (i.e. SIEM) which includes identifies visibility gaps such as Domain Controllers that don't have appropriate logging and/or aren't sending events to the system.

- Real-world risk of the actual enterprise configuration which may include the following:
    - Identification of regular user accounts which have privileged access to sensitive systems
    - Discovery of service accounts with credentials on systems that could provide privilege escalation

Conclusion

The ESP has led to impactful mitigation of risks that, if exploited, would have had a severe impact on the business of our clients. These risks are often missed by red teams, penetration tests, and other assessments. Trimarc seeks to solve two primary issues in enterprise security:

- **Risk Fatigue**: Admins and users become numb to potential security risks due to the complex, ever changing, and frequent requirements of maintaining a secure network.
- **Risk Intelligence**: Empowering teams and organizations across an enterprise to understand their risk profile as well as how other people's risks impact them.

Our service empowers our customers to better understand the risks in their enterprise across complex organizational structures and technologies. This approach encourages leadership in all roles from strategists to tacticians to make informed risk-based decisions to reduce risk and cost of security incidents.

Hope you have enjoyed this Trimarc ESP introductory article. Expect to learn more details in our upcoming webcasts and blog articles. We are looking forward to showing more of the advanced technical features. In this series, we are particularly excited to demonstrate:

- How regular user and administrator behavior plays a significant role in risk for the enterprise
- How sets of misconfigurations across Windows servers and excessive AD rights allow malware to propagate
- How permission models for business applications can lead to compromise the entire enterprise

Be sure to join our webcast, on Wednesday, May 25th from 2pm - 3pm Eastern to learn more or stay tuned for our upcoming blog posts. Trimarc ESP webcast registration link: https://trimarc.co/TrimarcWebcastRegisterESP202205

Trimarc provides leading expertise in security solutions including security reviews, strategy, architecture, and implementation. Our methodology leverages our internal research and custom tooling which better discovers multiple security issues attackers could exploit to

compromise the environment. Trimarc security services fit between traditional compliance/audit reviews and standard penetration testing/red teaming engagements, providing deep understanding of Microsoft and Virtualization technologies, typical security issues and misconfigurations, and provide recommendations based on our own best practices custom-tailored to balance operational and security challenges.

How to contact Trimarc